

# **Information Security**

# Fundamental Security Design Principles

- Despite years of research, it is still difficult to design systems that comprehensively prevent security flaws
- But good practices for good design have been documented
  - Economy of mechanism, fail-safe defaults, complete mediation, open design, separation of privileges, least privilege, least common mechanism, psychological acceptability, isolation, encapsulation, modularity, layering, least astonishment

# Fundamental Security Design Principles

- **Economy of mechanism:** the design of security measures should be as simple as possible
  - The checking and testing process is less complex
  - Fewer possibilities exist for errors
- **Fail-safe default:** access decisions should be based on permissions
  - Default, all the mechanism should have a lack of access

# Fundamental Security Design Principles

- **Complete mediation:** every access should be checked against an access control system
- **Open design:** the design should be open rather than secret
  - Like in the cryptographic algorithm, the encryption key is kept secret while the encryption algorithm is opened for a public investigation.

# Fundamental security design principles

- **Isolation**

- The system that has critical data, processes or resources must be isolated from public access.
- The files or data of one user must be kept isolated with the files or data of another user.
- Security mechanism must be isolated from unwanted access.

# Fundamental security design principles

- **Encapsulation:** similar to object concepts (hide internal structures)
- **Modularity:** security mechanism must be generated as separate and protected modules
- **Layering (defense in depth):** applying multiple security layers provides multiple barriers to the adversary, if he tries to access the protected system.

# Fundamental security design principles

- **Least astonishment:** a program or interface should always respond in a way that is least likely to astonish a user
- **Separation of privilege:** multiple privileges should be needed to do achieve access (or complete a task)
  - Least privilege: Only those limited privileges should be assigned to the user which are essential to perform the desired task.

# Fundamental security design principles

- **Least common mechanism:** a design should minimize the function shared by different users
- **Psychological acceptability:** Security mechanisms designed to protect the system should not interfere with the working of the user every time.
  - Security mechanism should introduce minimum hurdles to the user of the system